

Assignment 2: Researched-Based Implementation Strategy

Course: ISO/IEC 27001 Lead Implementer

Scenario: Preventing the Equifax 2017 Breach Through an ISO/IEC 27001:2022 ISMS

Case Study: Equifax Data Breach (2017)

Prepared As: Research Report

Prepared by: Lead Implementer OLANIPEKUN ADEBUKOLA

1. Executive Summary & Context

1.1 Executive summary

The 2017 Equifax data breach was a major failure of information-security governance, risk management, and technical control implementation. Attackers exploited CVE-2017-5638, a critical vulnerability in Apache Struts, through Equifax's internet-facing Automated Consumer Interview System (ACIS), an online dispute portal. Although the vulnerability had been disclosed in early March 2017 and Equifax's security team was aware of it, the affected application remained unpatched. Unauthorized access is believed to have occurred from May 13 through July 30, 2017.

The breach exposed highly sensitive personal information; including names, dates of birth, addresses, Social Security numbers, driver's-license information in some cases, and payment-card information. The U.S. Federal Trade Commission (FTC) stated that approximately 147 million people were affected, including 145.5 million Social Security numbers and approximately 209,000 payment-card numbers. The resulting regulatory settlement required Equifax to pay at least \$575 million, with potential liability up to \$700 million.

While Apache Struts was the initial technical entry point, the incident was not merely a "missed patch." It represented a systemic breakdown. The FTC found that Equifax failed to ensure timely patching, did not adequately segment databases, lacked robust intrusion detection for legacy databases, retained credentials and sensitive data in plain text, and did not establish effective safeguards to limit an attacker's movement after initial compromise.

This report applies ISO/IEC 27001:2022 to the Equifax incident. It identifies failures against Clauses 4-10, selects applicable Annex A controls for a Statement of Applicability (SoA), and proposes a six-month Plan-Do-Check-Act implementation roadmap. The core conclusion is that an effective ISMS would not guarantee that Equifax would never be attacked; however, it would have made exploitation substantially less likely and would have limited the scale, duration, and impact of the compromise.

1.2 Breach overview

Equifax operated as a major consumer-credit reporting organization, handling personal and financial data at exceptional scale. The company's own 2017 public statement described its database as containing information on more than 820 million consumers and more than 91 million businesses globally. Such an environment should have been treated as high risk because data loss could create lasting identity-theft, fraud, privacy, reputational, and regulatory consequences.

The attack sequence can be summarized as follows:

1. A critical Apache Struts vulnerability affecting the web-facing ACIS application was publicly disclosed in early March 2017.
2. Equifax security personnel became aware of the vulnerability and instructed vulnerable systems to be patched.
3. The organization did not adequately verify that remediation had occurred.
4. Attackers exploited the unpatched ACIS application and gained access to Equifax's network.
5. They located an unsecured file containing administrative credentials stored in plain text.
6. Those credentials enabled access to sensitive consumer information and allowed attackers to remain active for months.
7. Weak network segmentation, inadequate monitoring, and insufficient controls over legacy databases increased the scope of the compromise.

Equifax reported that suspicious network traffic was observed on July 29, 2017, and that the affected web application was taken offline on July 30. The FTC later stated that Equifax's security team had ordered patching within 48 hours of the March alert but had not followed up to confirm that responsible employees actually completed it.

1.3 Context of the organization: Clause 4.1

Clause 4.1 requires an organization to determine external and internal issues relevant to its purpose and that affect its ability to achieve intended ISMS outcomes. At Equifax, the organizational context should have led senior management to classify protection of consumer identity data and resilience of internet-facing systems as strategic, board-level priorities.

Internal issues

Internal context issue	Effect on information-security risk
Large, complex technology environment	Made complete asset identification, vulnerability tracking, configuration control, and accountability more difficult.
Legacy and custom-built systems	Increased the risk of unsupported components, inconsistent security configurations, weak integration, and delayed remediation.
Aggressive growth and acquisition strategy	Created pressure to prioritize business expansion and operational continuity over modernization and security investment.
Fragmented security accountability	Created a gap between security-policy development and execution by IT operations.
Incomplete system inventory	Prevented reliable identification of vulnerable assets and their owners.
High-value consumer data holdings	Made Equifax an attractive target and magnified the impact of any security failure.
Internet-facing dispute portal	Expanded the attack surface and required strict secure-development, patching, monitoring, and access-control practices.

The House investigation described a culture of cybersecurity complacency and found that Equifax’s rapid growth contributed to a complex legacy environment that it was not prepared to secure. It also noted that Equifax lacked a complete inventory of IT systems and had not sufficiently funded efforts to create one.

The internal context therefore required Equifax to recognize that its most significant information-security risks were not limited to malware or external attackers. They also included unclear ownership, unverified patching, unmanaged legacy systems, inadequate monitoring, insufficient segmentation, and the accumulation of sensitive data.

External issues

Equifax also faced significant external obligations and pressures:

- Regulatory expectations: As a consumer-reporting and financial-information organization, Equifax was subject to expectations under the Gramm-Leach-Bliley Act (GLBA) Safeguards Rule to maintain a comprehensive program protecting the security, confidentiality, and integrity of customer information.
- Consumer-protection expectations: Consumers expected Equifax to protect information that they often did not directly choose to provide and could not practically replace after exposure, such as Social Security numbers and credit-history data.
- Legal and enforcement exposure: The breach resulted in federal, state, and territorial enforcement activity. The FTC, CFPB, and 50 U.S. states and territories participated in the resulting settlement.
- Technology and threat environment: Publicly disclosed vulnerabilities in popular open-source components were actively weaponized by attackers, requiring rapid vulnerability intelligence, emergency change procedures, and verification of remediation.
- Reputational dependency: Equifax's business model depended on trust from consumers, lenders, insurers, employers, government entities, and commercial customers.

A properly implemented Clause 4.1 process would have documented these internal and external issues, linked them to risk assessment, and ensured that executive leadership funded security capabilities proportional to the organization's risk exposure.

1.4 Interested parties: Clause 4.2

Clause 4.2 requires the organization to determine interested parties relevant to the ISMS and their information-security requirements. The Equifax breach harmed multiple groups.

Interested party	Harm or security requirement
Consumers	Protection of personally identifiable information, timely notice, identity-theft support, accurate credit data, and accessible remediation.
Business customers	Assurance that credit-reporting data, analytics, and related services remain confidential, accurate, and available.

Interested party	Harm or security requirement
Regulators	Demonstrable compliance with data-protection, consumer-protection, reporting, and security-program requirements.
Shareholders and board	Protection of enterprise value, legal compliance, operational resilience, and credible risk reporting.
Employees	Clear security responsibilities, training, escalation paths, and a workable operating model.
Technology suppliers and service providers	Defined security requirements, assurance obligations, vulnerability disclosure expectations, and incident coordination.
Law enforcement	Timely, accurate forensic evidence and cooperation during investigation.
Society and credit ecosystem	Confidence that credit-reporting systems can be relied upon without exposing individuals to disproportionate identity-theft risk.

The affected consumers were the most directly harmed party. The FTC noted that the breach exposed personal data that could facilitate identity theft and fraud. Because Social Security numbers and dates of birth cannot be easily changed, the consequences could persist long after the incident itself.

2. Root Cause Analysis Through ISO/IEC 27001

The Equifax breach indicates failures not only in specific technical controls but also in the ISMS management-system requirements in Clauses 4-10. At least five major clauses appear to have been absent, inadequately implemented, or ineffective in practice.

2.1 Clause 4.1: Understanding the organization and its context

Equifax's apparent inability to identify all affected Apache Struts systems demonstrates that it did not sufficiently understand its technology environment as part of its organizational context. The House investigation found that the organization lacked a complete inventory of IT systems.

An ISO/IEC 27001:2022-aligned implementation would have required Equifax to document:

- The reliance on internet-facing legacy applications.
- The number and business criticality of systems processing consumer PII.
- The dependency on open-source components such as Apache Struts.
- The security impact of mergers, acquisitions, rapid growth, and technology fragmentation.
- The business consequences of compromise of credit-reporting data.
- The requirement to maintain security during modernization and business expansion.

Without this context, risk treatment was reactive and incomplete. A vulnerability-notification email alone was treated as a sufficient process response, even though the organization's scale and complexity demanded verified asset discovery, remediation tracking, executive escalation, and exception management.

2.2 Clause 5.1 and Clause 5.3: Leadership, commitment, and organizational roles

Clause 5.1 requires top management to demonstrate leadership and commitment to the ISMS. Clause 5.3 requires roles, responsibilities, and authorities to be assigned and communicated.

The House investigation described unclear authority between Equifax's IT and security functions. The security organization developed practices, but IT operations implemented them. The separation created an accountability gap because security personnel lacked direct authority over the operational teams expected to execute remediation.

This failure contributed directly to the unpatched server:

- Security issued a patching instruction.
- IT teams were expected to execute it.
- No accountable owner was clearly responsible for confirming the vulnerable asset had been remediated.
- No formal escalation occurred when confirmation was absent.
- Senior management apparently did not receive timely risk reporting showing that a critical, internet-facing vulnerability remained unresolved.

An effective implementation would have assigned a named executive owner for the ISMS, a CISO with sufficient authority, accountable system owners, and a clearly defined risk-acceptance authority. It would also have required the board or executive committee to review unresolved critical vulnerabilities that exceeded defined remediation timelines.

2.3 Clause 6.1.2: Information-security risk assessment

Clause 6.1.2 requires an organization to define and apply a process for information-security risk assessment. The process must establish risk criteria, identify risks, analyze them, evaluate them, and produce consistent, valid, and comparable results.

Equifax should have assessed the combination of:

- An internet-facing application.
- A known critical remote-code-execution vulnerability.
- Access to consumer-dispute systems.
- Connectivity to internal databases.
- Administrative credentials stored in plain text.
- Legacy databases containing highly sensitive PII.
- Weak segmentation and incomplete monitoring.

The FTC found that Equifax failed to patch the known vulnerability, inadequately segmented databases, lacked robust intrusion detection for legacy databases, and stored credentials and sensitive information in plain text. These are not isolated issues; they form a foreseeable high-risk scenario.

A risk assessment should have rated this scenario as intolerable or above the organization's risk appetite. The treatment decision should have required immediate patching or removal from service, followed by compensating controls if remediation could not occur within the approved time limit.

2.4 Clause 6.1.3: Information-security risk treatment

Clause 6.1.3 requires the organization to select appropriate treatment options, determine the controls necessary to implement them, compare them with Annex A, and produce a Statement of Applicability that justifies included and excluded controls.

Equifax's failure was not only that a patch was missed; it was that there was no demonstrably effective risk-treatment system for critical vulnerabilities. A mature risk-treatment plan would have included:

- A formal emergency-patching process.
- Asset-level accountability.
- Technical verification through authenticated scanning or configuration checks.
- A risk register entry for any unpatched critical exposure.
- Documented compensating controls.
- Executive approval for any temporary exception.
- Time-bound remediation and revalidation.

The lack of segmentation and monitoring also reveals that risk treatment did not use defense in depth. A secure design assumes that perimeter and application controls can fail. The internal network should have prevented a compromised portal from accessing unrelated high-value databases.

2.5 Clause 7.5: Documented information

Clause 7.5 requires documented information to be controlled and available where needed. Equifax's patch-management operation appeared to lack reliable evidence that patch instructions were completed and validated.

The FTC stated that Equifax ordered patching within 48 hours but did not verify whether responsible employees had completed the work. In an ISO/IEC 27001 ISMS, the following documented information should have existed:

- An authoritative asset inventory and configuration-management database.
- A software bill of materials or component inventory for critical applications.
- Vulnerability records tied to affected assets.
- Patch tickets and change records.
- Evidence of successful patch deployment.
- Scan reports validating remediation.
- Exception approvals and risk-acceptance records.
- Records of management review and escalation for overdue critical items.

Without these records, management could not demonstrate control effectiveness or make defensible decisions about residual risk.

2.6 Clause 9.1: Monitoring, measurement, analysis, and evaluation

Clause 9.1 requires organizations to determine what must be monitored and measured, how results are evaluated, and when results are analyzed.

Equifax's detection capability was ineffective. The House investigation reported that an intrusion-detection system had been nonfunctional for 19 months because of an expired certificate; suspicious traffic was noticed after the certificate was renewed.

This reflects a failure to define and monitor key security-performance indicators, such as:

- Percentage of critical vulnerabilities remediated within SLA.
- Number of internet-facing assets without confirmed ownership.
- Percentage of privileged credentials stored in approved secrets-management systems.
- Network zones with unrestricted access to PII databases.
- Availability and health of intrusion-detection systems.
- Percentage of critical log sources forwarding successfully to the monitoring platform.
- Mean time to detect and contain suspicious activity.
- Number and age of risk-treatment exceptions.

If Equifax had measured these indicators, management would have seen that its control environment was operating below an acceptable threshold.

2.7 Clause 9.2 and Clause 9.3: Internal audit and management review

Clause 9.2 requires internal audits to verify conformity and effectiveness. Clause 9.3 requires top management to review the ISMS at planned intervals.

An effective internal audit would have tested whether:

- The patch-management policy was being followed.
- Asset owners were known and accountable.
- Critical vulnerability remediation was independently validated.
- Legacy systems were included in scanning and monitoring.
- Credentials were protected appropriately.
- Database segmentation was technically enforced.
- Detection tooling was operational.

Management review should then have considered audit results, security performance, changes in external threats, risk-treatment status, resource needs, and improvement opportunities. The House investigation described a failure to prioritize and resource security adequately amid organizational growth. That is precisely the type of strategic issue Clause 9.3 is designed to surface.

3. Risk Treatment Plan

3.1 Risks that should have been identified

Before the breach, the following risks should have appeared in Equifax's information-security risk register:

Risk ID	Risk statement	Inherent risk
R-01	A known critical vulnerability in an internet-facing application may be exploited before remediation is verified.	Extreme
R-02	Incomplete asset and software-component inventory may prevent identification of vulnerable systems.	High
R-03	Weak or absent segmentation may allow attackers to pivot from a compromised web application to sensitive databases.	Extreme
R-04	Plain-text administrative credentials may allow privilege escalation and access to restricted systems.	Extreme
R-05	Inadequate event monitoring and detection may allow attackers to remain undetected for extended periods.	Extreme
R-06	Legacy systems may lack modern security baselines, logging, encryption, and patch support.	High
R-07	Unclear ownership of patching and security exceptions may cause critical remediation activities to fail.	High
R-08	Excessive data retention and unrestricted access to PII may increase breach impact.	High

3.2 Statement of Applicability controls

The following Annex A controls from ISO/IEC 27001:2022 should have been selected for Equifax's SoA. More than five controls are included because the attack required a layered treatment strategy.

Annex A control	Control title	Risk addressed
A.5.2	Information security roles and responsibilities	R-01, R-07
A.5.7	Threat intelligence	R-01
A.5.9	Inventory of information and other associated assets	R-02
A.5.24	Information security incident management planning and preparation	R-05
A.5.26	Response to information security incidents	R-05
A.8.8	Management of technical vulnerabilities	R-01, R-06
A.8.9	Configuration management	R-02, R-06
A.8.15	Logging	R-05
A.8.16	Monitoring activities	R-05
A.8.20	Network security	R-03
A.8.22	Segregation of networks	R-03
A.8.24	Use of cryptography	R-04, R-08
A.8.2	Privileged access rights	R-04
A.8.3	Information access restriction	R-03, R-08
A.8.12	Data leakage prevention	R-08

3.3 Control justifications and attack-chain disruption

A.5.2 :- Information security roles and responsibilities

Equifax should have established clear ownership for every business-critical application, infrastructure component, vulnerability-remediation task, and risk exception.

Implementation requirements:

- Assign a business owner, technical owner, and security owner for ACIS.
- Define who receives vulnerability notices, who validates exposure, who deploys patches, and who confirms closure.
- Require escalation to the CISO and executive risk committee when a critical internet-facing vulnerability remains open beyond 48 hours.
- Assign named ownership for detection tooling, certificates, and monitoring-platform health.

How it would have disrupted the attack chain:

The primary failure was that patching was ordered but not verified. Clear ownership would have made a specific individual or team accountable for patch completion and evidence. The vulnerability could have been remediated before exploitation.

A.5.7:- Threat intelligence

Equifax needed a structured process to collect, analyze, and act on threat intelligence from U.S. CERT, vendors, open-source maintainers, vulnerability databases, and security researchers.

Implementation requirements:

- Subscribe to authoritative vulnerability intelligence sources.
- Correlate new high-severity CVEs against the asset and software inventory.
- Define an emergency-risk rating for actively exploitable remote-code-execution vulnerabilities affecting public-facing applications.
- Trigger automatic incident-like response procedures for critical exposures.

How it would have disrupted the attack chain:

CVE-2017-5638 was publicly disclosed in March 2017. Threat intelligence should have elevated it as an urgent exposure requiring asset discovery, emergency patching, validation, and executive escalation—not merely distribution of a notification.

A.5.9:- Inventory of information and other associated assets

Equifax needed a comprehensive inventory of applications, servers, databases, network paths, data repositories, software components, service accounts, certificates, and system owners.

Implementation requirements:

- Maintain a centralized configuration-management database.

- Record business criticality, data classification, internet exposure, owner, operating system, application framework, and dependencies.
- Maintain a software-component inventory for web applications, including Apache Struts versions.
- Reconcile asset records with active network-discovery and vulnerability-scanning results.

How it would have disrupted the attack chain:

An accurate inventory would have identified every ACIS-related server using vulnerable Apache Struts. It also would have identified the application's access to internal databases and enabled security teams to prioritize high-risk assets.

A.8.8:- Management of technical vulnerabilities

A.8.8 is the central control for this incident. It requires organizations to obtain information about technical vulnerabilities, evaluate exposure, and take appropriate measures.

Implementation requirements:

- Establish remediation SLAs based on vulnerability severity, exploitability, asset exposure, and data sensitivity.
- Require critical vulnerabilities on internet-facing systems to be remediated within 24-48 hours or removed from service.
- Verify patching with authenticated vulnerability scans, version checks, and configuration validation.
- Require documented compensating controls and formal risk acceptance for exceptions.
- Report overdue critical vulnerabilities to executive management and the board.

How it would have disrupted the attack chain:

The attack began because Apache Struts remained unpatched. A properly implemented A.8.8 process would have identified the vulnerable ACIS asset, required emergency patching, independently verified the fix, and prevented the initial compromise.

A.8.9:- Configuration management

Configuration management would have ensured that systems, applications, certificates, security tools, firewall rules, and hardening requirements were defined, approved, monitored, and reviewed.

Implementation requirements:

- Establish secure build baselines for web applications and legacy databases.
- Track approved versions of Apache Struts and other dependencies.
- Monitor unauthorized configuration drift.
- Track certificate expiration for intrusion-detection and monitoring systems.
- Require controlled change records for application patches, firewall changes, and database-access modifications.

How it would have disrupted the attack chain:

Configuration management would have reduced the likelihood of the unpatched framework persisting unnoticed and would have prevented the monitoring-control failure caused by an expired certificate.

A.8.2:- Privileged access rights

Equifax reportedly retained administrative credentials in an unsecured plain-text file. Privileged access should have been strictly limited, monitored, approved, and protected.

Implementation requirements:

- Eliminate plain-text passwords and hard-coded credentials.
- Use privileged-access management and a centralized secrets vault.
- Require multi-factor authentication for privileged accounts.
- Implement periodic access recertification.
- Use distinct, least-privilege service accounts for applications and databases.
- Rotate credentials after changes, suspected exposure, or defined intervals.

How it would have disrupted the attack chain:

Even if attackers had compromised the web application, they would not have found reusable administrative credentials in plain text. Their ability to escalate privilege and access sensitive databases would have been severely reduced.

A.8.20:- Network security and A.8.22- Segregation of networks

The FTC found that Equifax did not adequately segment databases to prevent an attacker from accessing other areas after compromising one system.

Implementation requirements:

- Place public-facing applications in a dedicated demilitarized zone.
- Separate web, application, identity, analytics, and database tiers.
- Use allow-list firewall rules and microsegmentation.
- Permit the ACIS application to reach only the minimum necessary services and databases.
- Separate production, development, testing, administrative, and monitoring networks.
- Review network paths periodically and after major changes.

How it would have disrupted the attack chain:

The House investigation reported that the initially compromised system could reach more than 40 internal databases despite needing access to only three. Segmentation and least-privilege connectivity would have limited lateral movement and dramatically reduced the volume of accessible data.

A.8.15:- Logging and A.8.16:- Monitoring activities

Equifax needed comprehensive event logging and active monitoring of internet-facing applications, authentication, privileged activity, database queries, data exports, certificate health, and security-control status.

Implementation requirements:

- Centralize logs in a security information and event management platform.
- Monitor anomalous traffic, privilege escalation, unusual database queries, bulk exports, and access from the ACIS environment.
- Alert on disabled sensors, expired certificates, missing log feeds, and monitoring-system failures.
- Conduct 24/7 security operations monitoring for high-value environments.
- Test detection rules through simulated attack scenarios.

How it would have disrupted the attack chain:

Attackers were able to remain undetected for months. Effective monitoring would have detected exploitation attempts, unusual outbound traffic, suspicious credential use, and abnormal database access much earlier, limiting dwell time and data loss.

A.5.24 and A.5.26:- Incident-management planning and response

Equifax required documented procedures, trained personnel, decision authority, legal coordination, communications plans, forensic preservation, and defined containment actions.

Implementation requirements:

- Establish an incident-response plan for critical web-application compromise.
- Define thresholds for taking systems offline, rotating credentials, isolating network segments, and engaging external forensics.
- Conduct tabletop exercises involving executives, legal, communications, regulators, and customer-support teams.
- Maintain tested playbooks for credential compromise, data exfiltration, and public notification.

How it would have disrupted the attack chain:

These controls would not necessarily have prevented exploitation, but they would have accelerated detection, containment, evidence preservation, customer communication, and regulator engagement. The breach duration and downstream harm would likely have been reduced.

3.4 Residual risk and treatment governance

Risk treatment must not end with selecting controls. Equifax should have maintained treatment records containing:

- Risk owner.
- Asset and data classification.
- Inherent and residual risk ratings.
- Applicable legal and contractual requirements.
- Selected Annex A controls.
- Implementation milestones.
- Evidence of operating effectiveness.
- Exceptions, compensating controls, expiry dates, and executive approvals.
- Review dates and key risk indicators.

For example, if the Apache Struts patch had been technically difficult to deploy, the residual risk could not simply have been accepted informally. Equifax should have temporarily removed the affected portal from internet access or introduced compensating controls such as web-application firewall protections, increased monitoring, strict network isolation, and restricted application privileges. Any exception should have required executive approval and a short, nonrenewable remediation deadline.

4. Six-Month ISMS Implementation Roadmap

The following roadmap uses the Plan-Do-Check-Act model to rebuild Equifax's security program after the breach.

4.1 Months 1-2: Plan

Governance and leadership

- Appoint an executive ISMS sponsor and empower a CISO with authority over security policy, risk treatment, and escalation.
- Establish an Information Security Steering Committee including the CEO, CIO, CISO, legal, privacy, risk, internal audit, human resources, operations, and business-unit leadership.
- Define risk appetite for consumer PII, critical vulnerabilities, internet-facing systems, privileged access, and regulatory nonconformity.
- Issue a formal information-security policy approved by top management.

Scope and context

- Define the ISMS scope to include consumer-data platforms, internet-facing applications, legacy databases, identity systems, cloud services, third parties, corporate networks, and security operations.
- Perform a Clause 4.1 context analysis covering business growth, acquisition activity, legacy technology, regulatory obligations, consumer expectations, and threat environment.

- Identify and document interested parties under Clause 4.2, including consumers, regulators, lenders, business customers, employees, shareholders, suppliers, and law enforcement.

Risk assessment and SoA

- Build a risk-assessment methodology aligned with Clause 6.1.2.
- Establish risk criteria that treat exposed PII and public-facing critical vulnerabilities as high-impact conditions.
- Create an initial enterprise risk register.
- Produce an initial Statement of Applicability using the 2022 Annex A controls.
- Prioritize urgent controls: A.5.2, A.5.9, A.5.7, A.8.8, A.8.2, A.8.15, A.8.16, A.8.20, A.8.22, A.8.9, A.5.24, and A.5.26.

Trust-building actions

- Provide regulators with a documented remediation plan, accountable executives, milestones, and reporting cadence.
- Establish a consumer-remediation program with clear identity-protection services, help channels, and transparent public communications.
- Communicate openly to employees about reporting obligations, non-retaliation, and accountability expectations.

4.2 Months 2-4: Do

Asset and vulnerability management

- Create a verified enterprise asset inventory, including applications, databases, cloud workloads, operating systems, network devices, software dependencies, service accounts, and certificates.
- Implement continuous discovery to detect unknown assets.
- Deploy centralized vulnerability management with authenticated scanning.
- Establish remediation SLAs:
 - Critical internet-facing vulnerability: 24-48 hours.
 - Critical internal vulnerability: 7 days.
 - High vulnerability: 14-30 days, depending on risk.
- Require evidence-based closure for all remediation tickets.
- Establish a formal exception process with compensating controls and executive risk approval.

Architecture and technical controls

- Segment networks into web, application, database, management, development, testing, and monitoring zones.

- Restrict application-to-database connectivity to approved ports, services, and minimum required destinations.
- Deploy privileged-access management, a secrets-management platform, multi-factor authentication, and automated credential rotation.
- Encrypt sensitive data in transit and at rest; eliminate plain-text storage of passwords, secrets, and high-risk identifiers.
- Implement centralized logging and a security operations center capability.
- Monitor security-control health, including expired certificates, disabled sensors, missing log feeds, and failed scans.
- Establish secure configuration baselines for web servers, application frameworks, databases, endpoints, and cloud services.

People and process

- Train technical teams on secure patching, vulnerability triage, incident escalation, secure configuration, and evidence retention.
- Train business and executive teams on risk ownership, data classification, incident communications, and regulatory responsibilities.
- Update supplier requirements for cloud, managed security, application-development, and data-processing providers.
- Conduct incident-response tabletop exercises involving cyber, legal, privacy, communications, executive leadership, and customer support.

4.3 Months 4-5: Check

Measurement and evaluation

Establish a monthly security dashboard for executives and the board:

Metric	Target
Critical internet-facing vulnerabilities remediated within SLA	100%
Known internet-facing assets with named owners	100%
Assets covered by authenticated vulnerability scanning	100%
Privileged accounts protected by MFA and PAM	100%
Security-log source coverage for critical systems	100%

Metric	Target
Network connections from web tier to nonapproved databases	0
Detection-platform health and certificate validity	100%
Overdue risk exceptions	0
Mean time to detect critical incidents	Downward trend
Mean time to contain critical incidents	Downward trend

Internal audit

- Conduct internal ISMS audits under Clause 9.2.
- Test whether the patch-management workflow works end to end.
- Sample critical vulnerabilities and verify closure against technical evidence.
- Test segregation controls by attempting unauthorized pathways between network zones.
- Review privileged-access records and secrets-vault adoption.
- Validate that critical systems forward logs and that alerts are reviewed.
- Audit risk-treatment plans, exceptions, and management approvals.

Independent assurance

- Engage an independent assessor to review program maturity and verify evidence.
- Provide periodic evidence packages to regulators, including progress against remediation commitments.
- Conduct penetration testing and red-team exercises focused on internet-facing applications and lateral-movement scenarios.

4.4 Months 5–6: Act

Corrective action and continual improvement

- Record all audit findings and security incidents as nonconformities or improvement opportunities.
- Perform root-cause analysis for recurring patching, asset, monitoring, or access-control failures.
- Assign corrective-action owners, target dates, and effectiveness-review criteria.
- Update the risk register, SoA, policies, technical baselines, and training based on results.
- Retire unsupported systems where risk treatment is no longer economically or technically viable.
- Fund a multi-year legacy-modernization program with security architecture as a mandatory design requirement.

Management review

Top management should conduct formal ISMS management review under Clause 9.3. Inputs should include:

- Status of prior actions.
- Changes in context and interested-party requirements.
- Audit results.
- Risk-assessment and treatment status.
- Security objectives and metrics.
- Incident trends.
- Supplier-performance results.
- Resource needs.
- Opportunities for improvement.

Outputs should include decisions on staffing, budget, modernization priorities, residual-risk acceptance, corrective actions, and reporting commitments.

Rebuilding trust

- Publish meaningful transparency reports on remediation progress and security improvements.
- Maintain clear consumer-support channels and identity-protection assistance.
- Brief regulators regularly with measurable evidence rather than general assurances.
- Provide board-level reporting that includes control effectiveness, overdue risks, and unresolved systemic issues.
- Establish a culture in which employees can report control failures without fear of retaliation.

5. Conclusion and Reflection

The Equifax breach demonstrates that information security is a management-system problem as much as a technology problem. Apache Struts was the initial exploit path, but the ultimate failure resulted from inadequate governance, unclear responsibilities, weak asset management, ineffective vulnerability treatment, poor credential protection, insufficient segmentation, and failed monitoring.

ISO/IEC 27001:2022 would have provided Equifax with a disciplined structure for understanding its context, identifying interested parties, assigning responsibility, assessing risk, selecting controls, monitoring effectiveness, auditing performance, and driving continual improvement. In particular, a

combination of Annex A controls; especially A.5.2, A.5.9, A.8.8, A.8.2, A.8.20, A.8.22, A.8.15, and A.8.16; would have interrupted several stages of the attack chain.

However, a compliant ISMS cannot guarantee that a breach will never occur. ISO/IEC 27001 is risk-based, not a promise of absolute security. Threats evolve, vulnerabilities can be unknown, people make mistakes, suppliers can fail, and attackers may eventually bypass individual controls. Compliance can also become superficial if an organization treats the standard as a documentation exercise rather than a living management system.

The purpose of an ISMS is therefore not to claim invulnerability. Its purpose is to ensure the organization understands its risks, applies proportionate controls, maintains evidence of effectiveness, detects failures quickly, responds competently, and improves continuously. Had Equifax operated such an ISMS before 2017, the Apache Struts flaw likely would have been patched before exploitation; if exploitation had still occurred, segmentation, privileged-access controls, monitoring, and incident response should have sharply limited the breach's impact.

References

Crowell & Moring. (2018, December 20). Lessons from the House report on the Equifax breach. [crowell](<https://www.crowell.com/en/insights/client-alerts/lessons-from-the-house-report-on-the-equifax-breach-tRBKUpg6sU8gxy6uRxaKo>)

Equifax Inc. (2017, September 15). Equifax releases details on cybersecurity incident, announces personnel changes. [investor.equifax](<https://investor.equifax.com/news-events/press-releases/detail/237/equifax-releases-details-on-cybersecurity-incident>)

Federal Trade Commission. (2019, July 22). Equifax to pay \$575 million as part of settlement with FTC, CFPB, and states related to 2017 data breach. [ftc](<https://www.ftc.gov/news-events/news/press-releases/2019/07/equifax-pay-575-million-part-settlement-ftc-cfpb-states-related-2017-data-breach>)

International Organization for Standardization. (2022). ISO/IEC 27001:2022: Information security, cybersecurity and privacy protection; Information security management systems; Requirements.* ISO.

International Organization for Standardization. (2022). ISO/IEC 27002:2022: Information security, cybersecurity and privacy protection; Information security controls.